

GRC Dashboard Prototype Design - SecurePay

Prepared by: Ubuntu GRC

Date: 2025-06-12

1. Introduction

This document outlines the design for a lightweight GRC (Governance, Risk, and Compliance) dashboard prototype for SecurePay, a fictional SME. The dashboard is designed to visualize compliance status, risk posture, and incident metrics, providing a quick and intuitive overview for stakeholders. While this prototype is described for Google Sheets/Excel, the principles can be applied to other dashboarding tools.

2. Dashboard Objectives

- Provide a high-level overview of SecurePay's GRC posture.
- Enable quick identification of critical risks and compliance gaps.
- Visualize key performance indicators (KPIs) and key risk indicators (KRIs).
- Support informed decision-making by stakeholders.
- Automate scoring and risk indicators for real-time insights.

3. Dashboard Components

The dashboard will consist of several key sections, each providing specific insights:

3.1. Executive Summary

- Overall GRC Status: A single, prominent indicator (e.g., Green/Yellow/Red) representing the aggregated GRC health.
- Top 3 Risks: A concise list of the highest-rated risks from the risk register.
- Compliance Status: A summary of compliance against key regulations (POPIA, ISO 27001) with a percentage completion or status indicator.
- Incident Overview: Number of open incidents, average resolution time.

3.2. Risk Overview

- Risk Matrix: A visual representation of risks plotted by Likelihood vs. Impact, with color-coding (Green, Yellow, Red) for risk levels.
- Risk Trend: A simple line chart showing the trend of overall risk levels over time (e.g., monthly).
- Risk by Category: A bar chart showing the distribution of risks across different categories (e.g., Operational, Cyber, Regulatory).
- Risk Treatment Progress: A progress bar or percentage indicating the completion of mitigation actions for high/critical risks.

3.3. Compliance Status

- POPIA Compliance: Progress against the 8 conditions of POPIA (e.g., a checklist with completion status).
- ISO 27001 Annex A Controls Implementation: Progress against the implementation of selected Annex A controls, grouped by theme (Organizational, People, Physical, Technological).
- Policy Review Status: A list of key policies and their last review dates, with indicators for upcoming reviews.

3.4. Incident Management

- Incident Volume: A bar chart showing the number of incidents reported per month.
- Incident Type Breakdown: A pie chart showing the distribution of incidents by type (e.g., Phishing, Malware, Data Breach, System Outage).
- Mean Time To Detect (MTTD) / Mean Time To Respond (MTTR): Key metrics for incident response efficiency.

4. Automated Scoring and Risk Indicators

The dashboard will leverage conditional formatting and simple formulas to provide automated scoring and visual risk indicators.

- Risk Indicators (Red/Yellow/Green):
 - Red: Critical risk, significant compliance gap, or high number of open incidents. Requires immediate attention.
 - Yellow: Medium risk, some compliance gaps, or moderate number of open incidents. Requires monitoring and action.

- Green: Low risk, strong compliance, or low number of open incidents. Good posture.
- Automated Scoring Logic (Example for Risk Level):
 - Risk Level (Likelihood * Impact) will be calculated automatically from the risk register data.
 - Conditional formatting rules will be applied to cells based on the calculated risk level:
 - `IF(Risk_Level >= 17,
 - IF(Risk_Level >= 17, "Red")
 - IF(Risk_Level >= 10 AND Risk_Level < 17, "Yellow")
 - IF(Risk_Level < 10, "Green")
- Compliance Percentage: Formulas will calculate the percentage of completed compliance tasks or implemented controls.
 - IF(Compliance_Percentage < 70%, "Red")
 - IF(Compliance_Percentage >= 70% AND Compliance_Percentage < 90%, "Yellow")
 - IF(Compliance_Percentage >= 90%, "Green")

5. Data Sources

The dashboard will pull data from:

- Risk Register: For risk identification, assessment, and treatment data.
- Compliance Checklists: For POPIA and ISO 27001 implementation status.
- Incident Management Log: For incident details, resolution times, and types.

6. Mock-up (Conceptual Layout for Google Sheets/Excel)

(Sheet 1: Dashboard Overview)

	A	B	C	D	E	F
1	G R C D a s h b o a r d SecurePay		-			

	A	B	C	D	E	F
2						
3	Overall GRC Status:	[Green/ Yellow/Red Indicator]		Top 3 Risks:		
4				1. [Risk Name		
5				1] 2. [Risk		
6				Name 2] 3.		
7				[Risk Name 3]		
8	Compliance Status:	[POPIA %]	[ISO 27001 %]			
9		POPIA	ISO 27001			
10	Incident Overview:	Open Incidents: [Count]	Avg. Resolution Time: [Days]			
11						
12	Risk Matrix (Conceptual) (Likelihood vs.			Risk Trend (Chart) (Line chart		
13	Impact plot with color-coded risks)			showing risk level over time)		
14						
15	Risk by Category (Chart)			Risk Treatment Progress (Chart) (Progress bar for		
16	(Bar chart of risk types)			mitigation actions)		

(Sheet 2: Risk Register Data - Linked to Sheet 1)

(Contains the detailed risk register table as drafted previously)

(Sheet 3: Compliance Checklists - Linked to Sheet 1)

Control/Requirement	Status (Implemented/Not Implemented)	Notes
POPIA Condition 1: Accountability	[Dropdown]	
POPIA Condition 2: Processing Limitation	[Dropdown]	
...		
ISO 27001 A.5.1: Policies for Information Security	[Dropdown]	
ISO 27001 A.6.1: Roles and Responsibilities	[Dropdown]	
...	[Dropdown]	

(Sheet 4: Incident Log - Linked to Sheet 1)

Incident ID	Date	Type	Status	Resolution Date	Notes
INC00	2025-05-10	Phishing	Closed	2025-05-12	
1	2025-06-01	Malware	Open		
INC00					

2 ...

7. Implementation Notes

- Use data validation for dropdowns (e.g., Status in Compliance Checklists).
- Utilize SUMIF, COUNTIF, and other logical functions for automated calculations.
- Apply conditional formatting extensively for visual indicators (Red/Yellow/Green).
- Charts can be created using the built-in charting features of Google Sheets/Excel.
- Ensure data consistency across linked sheets.